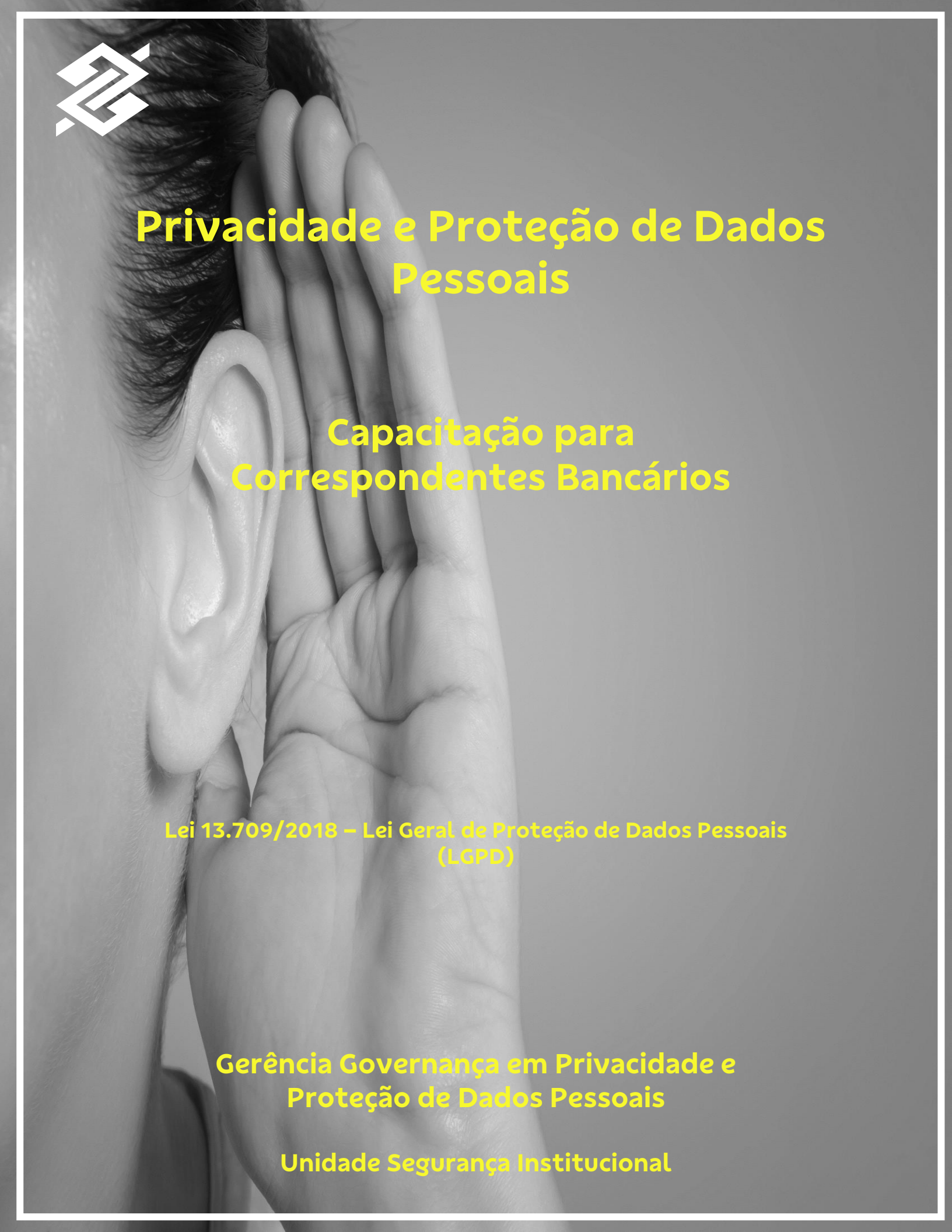


Privacidade e Proteção de Dados Pessoais

Capacitação para Correspondentes Bancários

Lei 13.709/2018 – Lei Geral de Proteção de Dados Pessoais (LGPD)

Gerência Governança em Privacidade e Proteção de Dados Pessoais

Unidade Segurança Institucional

Sejam bem vindos !

Este material pretende contribuir com a capacitação dos correspondentes sobre a Lei Geral de Proteção de Dados Pessoais – Lei 13.709/2018, em razão da Resolução CMN 4.935/2021, e tem por objetivo aprimorar a cultura de privacidade e proteção de dados pessoais junto a esse público, uma vez que o BB procura aliar-se com empresas que investem em boas práticas de governança e na proteção de dados pessoais.

Buscamos apresentar o tema privacidade e proteção de dados pessoais, com foco na LGPD, de forma clara e objetiva, por meio de uma linguagem acessível e com a utilização de exemplos práticos dos assuntos conduzidos pelos correspondentes. Também abordaremos medidas para minimização de riscos e conduta adequada no tratamento de dados pessoais.

Principais conceitos

Titular: é o dono do dado, tendo direito sobre ele. O objetivo primário da LGPD é proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural.

Dado pessoal: informação relacionada à pessoa natural identificada ou identificável. Qualquer dado que possa identificar direta ou indiretamente uma pessoa. O CPF é um exemplo de dado identificável direto e o endereço é um dado identificado indireto.

Dado pessoal sensível: é a informação relacionada à origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural. Para esses dados, devemos tomar cuidados adicionais.

Dado anonimizado: é aquele que não identifica um titular, geralmente obtido com a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento.

Tratamento de dados pessoais: qualquer operação realizada com dados pessoais, como coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação ou controle da informação, modificação, comunicação, transferência, difusão ou extração.

Papeis previstos na lei

Agentes de Tratamento

Controlador: pessoa natural ou jurídica, de direito público ou privado, responsável pelas decisões referentes ao tratamento de dados pessoais. O controlador é o agente responsável por tomar as principais decisões referentes ao tratamento de dados pessoais e por definir a finalidade deste tratamento. Entre essas decisões, incluem-se as instruções fornecidas a operadores contratados para a realização de um determinado tratamento de dados pessoais.

Operador: pessoa natural ou jurídica, de direito público ou privado, responsável por realizar o tratamento de dados pessoais em nome do controlador e somente conforme a finalidade previamente estabelecida pelo controlador.

Encarregado

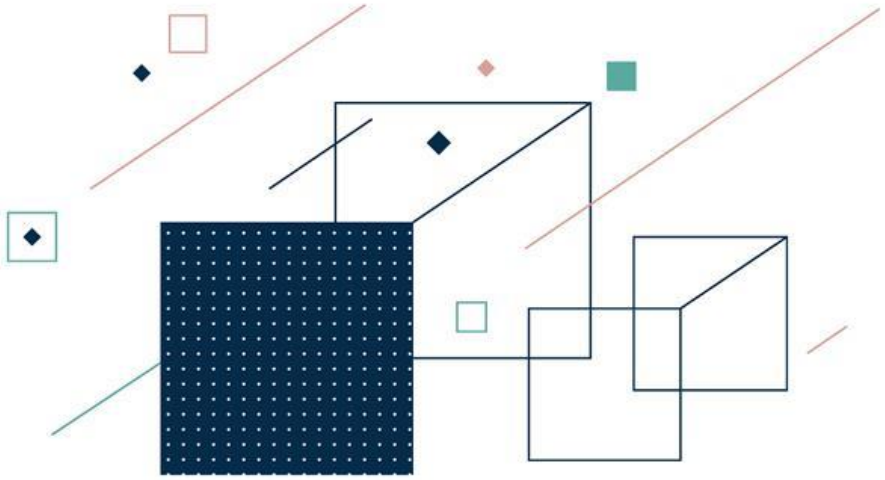
Pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a Autoridade Nacional de Proteção de Dados (ANPD). É o Encarregado quem deve garantir a relação perante o titular de dados e a ANPD. Para tanto, ele deve contar com uma estrutura de apoio, ter autonomia e independência no desempenho de suas funções. segurança, de *compliance*, de tecnologia da informação e de processos corporativos.

ANPD

A Autoridade Nacional de Proteção de Dados - ANPD é o órgão federal responsável por fiscalizar e aplicar a Lei 13.709/2018 - Lei Geral da Proteção de Dados – LGPD, zela pela proteção dos dados pessoais, nos termos da legislação.

É papel da ANPD regulamentar, implementar e fiscalizar o cumprimento da LGPD no Brasil. Nesse sentido, por exemplo, ela pode iniciar procedimentos administrativos para apurar eventuais irregularidades e inadequações dos agentes de tratamento.

Os processos administrativos podem ser motivados por denúncias de titulares, por comunicação de outros órgãos ou de ofício pela prória ANPD.



Princípios da LGPD

A LGPD elencou, em seu art. 6º, os princípios que cada atividades de tratamento de dados pessoais deve observar.

Finalidade

Realização do tratamento para propósitos legítimos, específicos, explícitos e informados ao titular do dado.

Transparência

Garantia, aos titulares, de informações claras, precisas e facilmente acessíveis sobre a realização do tratamento.

Necessidade

Limitação do tratamento ao mínimo necessário para a realização de suas finalidades.

Adequação

Compatibilidade do tratamento com as finalidades informadas ao titular, de acordo com o contexto do tratamento.

Segurança

Utilização de medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão.

Prevenção

Adoção de medidas para prevenir a ocorrência de danos em virtude do tratamento de dados pessoais.

Livre acesso

Garantia, aos titulares, de consulta facilitada e gratuita sobre a forma e a duração do tratamento, bem como sobre a integralidade de seus dados pessoais.

Qualidade dos dados

Garantia, aos titulares, de exatidão, clareza, relevância e atualização dos dados, de acordo com a necessidade e para o cumprimento da finalidade de seu tratamento.

Responsabilização e prestação de contas

Demonstração, pelo agente, da adoção de medidas eficazes e capazes de comprovar a observância e o cumprimento das normas de proteção de dados pessoais e, inclusive, da eficácia dessas medidas.

Não discriminação

Impossibilidade de realização do tratamento para fins discriminatórios ilícitos ou abusivos.

Atenção!

Os princípios da LGPD deverão ser considerados em todo tratamento de dados pessoais, do início ao fim do processo.

Dentre os princípios descritos, vamos trazer foco aos princípios da finalidade, necessidade e adequação, ou seja, o tratamento dos dados pessoais deve respeitar o propósito definido, de conhecimento do titular de dados e restrito aos dados necessários.

Abaixo apresenta-se uma situação *hipotética de utilização indevida de dados pessoais*

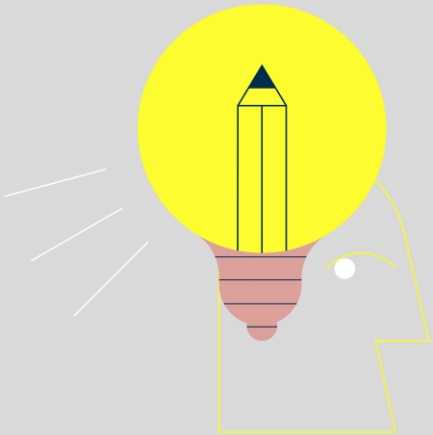
Um atendente do COBAN, sem observar os padrões de atendimento definidos pelo Banco do Brasil, acessou indevidamente os dados pessoais de diversos titulares, extrapolando as listas de clientes definidas pelo BB, no intuito de ofertar produtos destinados a público vulnerável. Os clientes solicitaram para não serem mais abordados e, ainda assim, as ofertas foram recorrentes. Logo, fizeram reclamação formal a respeito da violação dos seus dados pessoais.

Neste caso, houve violação de vários princípios da LGPD. O tratamento dos dados não foi adequado à finalidade previamente acordada e a necessidade do tratamento não se limitou ao uso de dados essenciais para alcançar a finalidade.

Como vimos na situação hipotética, casos similares causam aborrecimentos aos titulares de dados, podendo acarretar multa aos agentes envolvidos no tratamento dos dados pessoais, gerando risco de reputação para o BB e sanções contratuais ou administrativas para os próprios correspondentes bancários.

Desse modo, é necessário que os agentes de tratamento, com destaque para os correspondentes bancários que estão coletando e tratando os dados pessoais, obedeçam os procedimentos definidos pelo Banco do Brasil.

A coleta e tratamento deverá ficar restrita aos dados pessoais estritamente necessários para a finalidade definida pelo Banco do Brasil.



Execução de políticas públicas

Legítimo Interesse

Hipóteses legais que permitem o tratamento de dados pessoais

Só podemos tratar dados pessoais quando o objetivo do tratamento for compatível com uma das hipóteses trazidas pela LGPD (art. 7º e art. 11).

Exercício Regular do Direito em processo judicial

Consentimento

No BB, podemos tratar os dados pessoais quando o objetivo for:

Execução de políticas públicas	Legítimo interesse
Proteção ao crédito	Execução de contrato
Prevenção à fraude e segurança do titular	Cumprimento de obrigação legal ou regulatória
Exercício regular do direito em processo judicial	Consentimento

Outras hipóteses de tratamento previstas em lei:

Realização de estudos por órgão de pesquisa

Proteção da vida

Tutela da saúde

Execução de contrato

Quando o tratamento de dados pessoais é necessário para a execução de contrato ou de procedimentos preliminares relacionados a contrato do qual seja parte o titular, a pedido do titular dos dados.

Isso quer dizer que, quando o titular dos dados adquire um produto ou serviço do BB, seus dados serão tratados nas fases de coleta, processamento, armazenamento etc., respaldado por essa base legal. Mas não é só isso: como essa base legal prevê procedimentos preliminares, esses dados já podem ser tratados na **fase pré-contrato**, ou seja, quando o titular **pretende adquirir um produto ou serviço.**

Alguns exemplos no uso desta hipótese de tratamento: abertura de conta corrente; contratação de cartão de crédito

Proteção ao crédito

Essa base é amplamente utilizada pelas instituições financeiras para obter informações sobre adimplência e inadimplência do titular para a tomada de decisão na concessão do crédito.

Tem por finalidade garantir que em situações de concessão e condução de operações de crédito, as instituições financeiras e *bureau* de .crédito tenham segurança em tratar dados pessoais.

Alguns exemplos no uso desta hipótese de tratamento: Utilização do cadastro positivo e negativo, análise de risco de crédito e cálculo de limite de crédito.

Cumprimento de obrigação legal ou regulatória

Ocorre quando o tratamento de dados pessoais é necessário para poder garantir o cumprimento de leis, resoluções ou outros normativos legais.

Alguns exemplos no uso desta hipótese de tratamento: transmissão dos dados de funcionários para a Relação Anual de Informações Sociais (RAIS) ou o tratamento de dados para recolhimento de IOF em operações de crédito.

Prevenção à fraude e segurança do titular

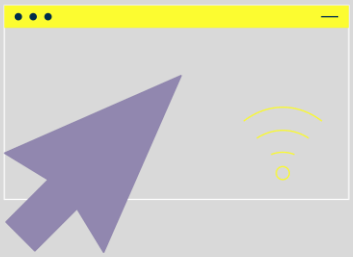
Esta base legal permite a utilização de dados pessoais, inclusive dados pessoais sensíveis, nos processos de identificação e autenticação de pessoas em sistemas eletrônicos.

Alguns exemplos no uso desta hipótese de tratamento: quando se faz uso da biometria para autenticar o titular e efetivar operações em um caixa eletrônico.

Consentimento

O consentimento permite que as empresas tratem dados pessoais para fins específicos mediante a autorização prévia do titular dos dados.

O consentimento do titular deve ser uma manifestação livre, informada e inequívoca pela qual o titular concorda com o tratamento de seus dados pessoais para uma finalidade determinada.

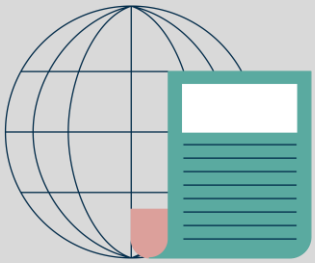


Alguns exemplos no uso desta hipótese de tratamento: compartilhamento de dados para cadastramento em promoções; tratamento de dados sensíveis.

Legítimo interesse

É a base legal que permite ao controlador de dados pessoais tratar os dados pessoais de determinados titulares para atender aos seus interesses legítimos ou de terceiros.

Os dados podem ser tratados no legítimo interesse do controlador desde que sempre sejam respeitados as expectativas e o direito de liberdade do titular, além de demonstrar o benefício por ele esperado.
Nessa hipótese, pode ser necessária a confecção do Relatório de Impacto à Proteção de Dados.

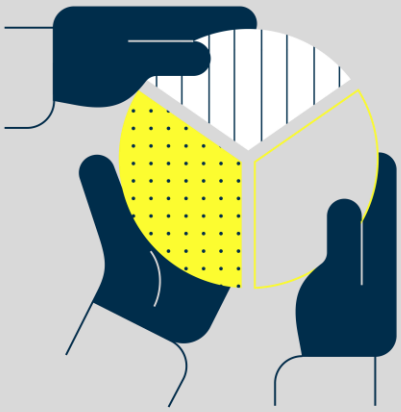


Alguns exemplos no uso desta hipótese de tratamento: oferta de um cartão de crédito; pesquisa com o cliente.

Exercício regular do direito em processo judicial

Garante ao controlador ou operador que ele possa utilizar os dados para exercer um direito reconhecido por lei, como, por exemplo, o direito de defesa, em processo judicial, administrativo ou arbitral.

Exemplo no uso desta hipótese de tratamento: quando o agente de tratamento é réu de algum processo judicial.



Execução de políticas públicas

Esta é uma hipótese legal mais restritiva da LGPD, pois se aplica somente ao setor público.

Garante ao poder público tratar e fazer uso compartilhado de dados pessoais se eles forem necessários para colocar em prática políticas públicas previstas em leis.

Alguns exemplos no uso desta hipótese de tratamento:
implementar programas de assistência social e de transferência de renda, prova de vida exigida pelo INSS, tratamento de dados dos familiares que possuem acesso ao programa Pronaf para financiamento da produção agrícola.

Incidente de Segurança

É definido como sendo qualquer evento adverso, confirmado ou sob suspeita, relacionado à segurança de sistemas de informação levando a perda de um ou mais princípios básicos de Segurança da Informação: Confidencialidade, Integridade e Disponibilidade.

Confidencialidade: a informação pode ser acessada apenas por pessoas autorizadas – isso significa o sigilo da informação.

Integridade: garante o controle das alterações, impedindo que pessoas não autorizadas façam alterações indevidas na informação. O princípio da integridade também garante a completude da informação, para que não haja perda ou alteração indevidas da informação.

Disponibilidade: A informação estará disponível sempre que for necessária.

Incidentes de Segurança com Dados Pessoais

O incidente de segurança com dados pessoais é definido como qualquer evento adverso confirmado, relacionado à violação na segurança de dados pessoais, tais como acesso não autorizado, acidental ou ilícito que resulte na destruição, perda, alteração, vazamento ou ainda, qualquer forma de tratamento de dados inadequada ou ilícita, os quais possam ocasionar risco para os direitos e liberdades do titular dos dados pessoais.

Situação hipotética envolvendo quebra da confidencialidade e consequente vazamento de dados pessoais

José trabalha no COBAN com recepção e encaminhamento de propostas de abertura de conta. Em um dos atendimentos, José imprimiu o contrato para o cliente conferir os dados e assinar o documento. Os dados pessoais como nome, CPF, data de nascimento estavam preenchidos corretamente, no entanto José precisou corrigir o endereço e reimprimiu novo documento, mas em vez de triturar o contrato incorreto, fez o descarte no lixo normal do ponto de atendimento do COBAN. Infelizmente, dias depois, este lixo foi encontrado remexido próximo ao ponto de atendimento. O ocorrido foi amplamente divulgado na mídia local causando consequências ao Banco do Brasil e à loja do correspondente bancário envolvido.

No caso de vazamento de dados pessoais, assim como no caso de qualquer incidente de segurança, o controlador e operador dos dados pessoais devem agir conjuntamente para sanar o problema e mitigar os riscos e danos ao titular.

Essa situação poderia ter sido evitada se o atendente agisse de maneira mais cuidadosa durante o atendimento ao cliente e prezasse pelo sigilo e confidencialidade dos dados pessoais que estava tratando. Nessa situação hipotética, o atendente agiu com descuido em relação ao descarte de dados pessoais.

Situações como as relatadas aqui podem gerar consequências aos titulares dos dados, pois consistem em um tipo de incidente de segurança que envolveu falta de cuidado com os documentos físicos que possuíam dados pessoais de clientes.

Destaca-se que, de acordo com a LGPD, os sistemas utilizados para o tratamento de dados pessoais devem ser estruturados de forma a atender aos requisitos de segurança, aos padrões de boas práticas e de governança e aos princípios gerais previstos nesta Lei e às demais normas regulamentares.

Além disso, o comportamento e atitude diligente e zelosa de todos os agentes envolvidos no tratamento dos dados pessoais são imprescindíveis para que os dados sejam tratados de maneira segura, sigilosa e confidencial durante todo o seu ciclo de vida.

Dúvidas? Estamos à disposição!

uac.imob@bb.com.br
uac.agro@bb.com.br

ATENÇÃO!

Pontos relevantes que o Correspondente Bancário deve observar:

Preciso mesmo utilizar essa quantidade de dados?

Quanto mais acesso às informações, maior será a sua responsabilidade, portanto, solicite e acesse apenas o que for necessário para sua operação.

As ferramentas utilizadas para a realização de contato com o cliente podem trazer algum risco?

Atente-se ao tipo de software ou meio utilizado para a realização dos contatos com os clientes e garanta que as informações trocadas por meio deles estejam protegidas ou criptografadas. Caso haja informação transmitida por meio de planilha ou sistemas inseguros e ocorrer vazamento de informações, a instituição pode ser penalizada e sujeita a sanções.

Quanto ao uso dos dados, a finalidade definida é a mesma que foi informada ao cliente?

No momento de iniciar a operação junto a um cliente, você deve explicar a finalidade e a necessidade pelo qual foi solicitado quaisquer dados pessoais na operação.

A LGPD deixa claro que, sob hipótese alguma, deve ser realizado o tratamento cuja finalidade seja diferente daquela informada ao titular dos dados.

Fontes de referência

- *Cartilha Segurança para Internet - Fascículo Proteção de dados.* Produzido por cert.br nic.br cgi.br. Com a contribuição da ANPD.

- *Cartilha Segurança para Internet – Fascículo Vazamento de Dados*. Produzido por cert.br nic.br cgi.br. Com a contribuição da ANPD.

- *Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado*. Versão 2.0. Abr. 2022 – ANPD.

- Lei: 13.709/2018 - Lei Geral de Proteção de Dados Pessoais – LGPD.

- Normativos Internos do Banco do Brasil.